北极星安全合规白皮书

内部资料 | 版本 1.0

3.1 合规认证

平台已通过 ISO 27001、ISO 27701、等保三级认证，SOC 2 Type II 报告每年更新。

认证范围覆盖生产环境与灾备环境，不包含测试环境。

审计报告可应客户要求提供，需签署保密协议。

3.2 数据分类分级

数据分为公开、内部、机密、绝密四级，机密及以上级别需要单独审批才能导出。

客户数据默认归类为机密，由客户自行调整分级。

分级标签随数据一起迁移，导出时保留。

3.3 加密与密钥

传输加密使用 TLS 1.3，存储加密使用 AES-256-GCM。

密钥每 180 天轮换一次，轮换过程对业务无感。

客户可自带密钥（BYOK），密钥由客户 KMS 托管，服务商无法读取明文。

3.4 访问控制

支持 RBAC 与 ABAC 两种模型，角色最多 5 层继承。

高危操作（删除库、导出全量数据）需要二次确认与审批流。

所有管理操作记录审计日志，日志保留 180 天，不可篡改。

3.5 数据出境

默认数据存储在中国大陆境内，不跨境传输。

如有出境需求，需完成安全评估并签署专项协议。

出境数据的加密要求不低于境内标准。

3.6 事件响应

安全事件分为四级，一级事件要求 1 小时内响应，24 小时内通报客户。

数据泄露事件须在 72 小时内向监管机构报告。

每年至少组织两次应急演练，演练结果纳入年度审计。